

R40.12

Revizyon No : 00

Yürürlük Tarihi : 13.01.2021

ISO/IEC 27701 ve ISO/IEC 20000-1 Belgelendirme Faaliyetlerinin Akreditasyonuna İlişkin Rehber



TÜRK AKREDİTASYON KURUMU

1. AMAÇ

Bu rehberin amacı; ISO/IEC 27701 ve ISO/IEC 20000-1 belgelendirme faaliyetlerinin akreditasyon süreçlerinde TÜRKAK kurallarını tanımlamaktır.

2. KAPSAM

Bu rehber; ISO/IEC 27701 ve ISO/IEC 20000-1 yönetim sistemi standartlarına yönelik belgelendirme faaliyetleri yürüten Uygunluk Değerlendirme Kuruluşlarının akreditasyon başvurularından akredite olana kadarki süreçleri ve kuralları kapsar.

3. ATIF YAPILAN DOKÜMANLAR

- İlgili IAF/EA dokümanları
- ISO/IEC 17021-1
- ISO/IEC 27006
- ISO/IEC 20000-6
- ISO/IEC 27001
- ISO/IEC 27000
- ISO/IEC 20000-1
- ISO/IEC 29100

4. TANIMLAR

ISO/IEC 17021-1, ISO/IEC 27006 ve ISO/IEC 20000-6 standartlarında verilen terim ve tarifler geçerlidir.

5. SÜREÇLERE İLİŞKİN GENEL KURALLAR

- 5.1 ISO/IEC 27701 ve ISO/IEC 20000-1 belgelendirme faaliyetleri için başvurular ve akreditasyon süreçleri P701 Uygunluk Değerlendirme Kuruluşlarının Akreditasyonu Prosedürüne göre yürütülmektedir.
- 5.2 Başvuru yapacak olan Uygunluk Değerlendirme Kuruluşu (UDK) F701-004 Başvuru Formunda yer alan "Tablo 1-Akreditasyon Talep Edilen Belgelendirme Kapsamı" kısmında talep etmiş olduğu kapsama ilişkin ISO/IEC 27701 ve/veya ISO/IEC 20000-1 standardını eklemelidir.
- 5.3 ISO/IEC 27701 belgelendirmesinin akreditasyon başvurusunun kabulü için ISO/IEC 27001 belgelendirme faaliyetlerinde TÜRKAK'tan akredite olmak zorunluluğu vardır. (Eğer ISO/IEC 27701 belgelendirme faaliyetleri için başvurmak isteyen UDK, ISO/IEC 27001 belgelendirme faaliyetleri için TÜRKAK'tan akredite değil ise ISO/IEC 27701 başvurusunun kabul edilebilmesi için ISO/IEC 27001 başvurusunda da bulunmak zorundadır.)
- 5.4 ISO/IEC 27701 belgelendirme faaliyetlerinin akreditasyonu için ISO/IEC 17021-1 ve ISO/IEC 27006 standartları akreditasyon için birlikte değerlendirilmektedir. (Akreditasyon için ISO/IEC 27701 için ISO/IEC 17021-1 seviye 3 iken ISO/IEC 27006 seviye 4 olarak akreditasyonda kullanılır.)
- 5.5 ISO/IEC 20000-1 belgelendirme faaliyetlerinin akreditasyonu için ISO/IEC 17021-1 ve ISO/IEC 20000-6 standartları akreditasyon için birlikte değerlendirilmektedir. (Akreditasyon için ISO/IEC 20000-1 için ISO/IEC 17021-1 seviye 3 iken ISO/IEC 20000-6 seviye 4 olarak kullanılır.)
- 5.6 Akreditasyon denetimlerinin planlanması, denetimlerin gerçekleştirilmesi denetim sonrası faaliyetler ve karar süreci P701 Uygunluk Değerlendirme Kuruluşlarının Akreditasyonu Prosedürüne göre gerçekleştirilir.



TÜRK AKREDİTASYON KURUMU

6 TANIK DENETİMLERE İLİŞKİN GENEL KURALLAR

- 6.1** Tanık denetimlere ilişkin genel kurallar TÜRKAK R40.05 rehberinin 5.1 maddesinde tanımlandığı gibi uygulanır.
- 6.2** Uygunluk Değerlendirme Kuruluşu (UDK), Aşama 1'in bir kısmını müşterinin yerinde (sahada) yapmalıdır. Aşama 1 ile Aşama 2 arasında, firmadaki bulgulara bağlı olarak makul bir süre olmalıdır. Uygunluk Değerlendirme Kuruluşları hem Aşama 1 hem de Aşama 2'ye yetkin tetkik ekibi (ilgili kapsamda atanmış) görevlendirmek zorundadır.
- 6.3** Planlı tanık denetimler; ilk akreditasyon, gözetim, kapsam genişletme ve akreditasyon yenileme denetimlerinde akredite olunmak istenen/akredite olunan her bir yönetim sistemi/belgelendirme programı için TÜRKAK R40.05 rehberi madde 6'da yer alan kurallara göre yapılır.
- 6.4** ISO/IEC 27701 belgelendirme faaliyetlerinde akredite olmak isteyen UDK'lar için ilk akreditasyon denetiminde en az bir adet Aşama 1 tetkiki ve en az bir adet Aşama 2 (ilk belgelendirme) tetkikine tanık denetim gerçekleştirilir. Gözetim ve akreditasyon yenileme denetimlerinde ise en az bir adet Aşama 2 veya gözetim veya belge yenileme tetkikine tanık denetim gerçekleştirilir.
- 6.5** ISO/IEC 20000-1 belgelendirme faaliyetlerinde akredite olmak isteyen UDK'lar için ilk akreditasyon denetiminde en az bir adet Aşama 1 tetkiki ve en az bir adet Aşama 2 (ilk belgelendirme tetkiki) tetkikine tanık denetim gerçekleştirilir. Gözetim ve akreditasyon yenileme denetimlerinde ise en az bir adet Aşama 2 veya gözetim veya belge yenileme tetkikine tanık denetim gerçekleştirilir.
- 6.6** Plansız saha ziyaretleri TÜRKAK R40.05 rehberi madde 6'da ki kurallara göre gerçekleştirilir.
- 6.7** Tanık denetimler TÜRKAK prosedürleri gereğince; şikâyetler ve iddiaların araştırılması, anlaşmazlıkların giderilmesi, piyasa veya düzenleyici kuruluşlardan geri bildirimler alınması vb. gibi başka gerekçelerle de gerçekleştirilebilir.
- 6.8** Tanık olunacak ilk belgelendirme tetkikinin Aşama 1 ve Aşama 2'sinin öncelikle aynı müşteri organizasyonda yapılması şartı aranır, makul bir gerekçe ile bunun mümkün olmadığı durumlarda farklı organizasyonlarda yapılması kabul edilebilir.
- 6.9** Yönetim sistemine bağlı olarak bu rehberde göre gösterilmesi gereken tanık denetimlerin UDK tarafından süresi içinde TÜRKAK tarafından kabul edilen makul bir gerekçe olmaksızın organize edilememesi durumunda ilgili kapsamlardaki akreditasyon askıya alınır.

7 ISO/IEC 27701 ve ISO/IEC 20000-1 BELGELENDİRME FAALİYETLERİNDE AKREDİTE OLMAK İSTEYEN UYGUNLUK DEĞERLENDİRME KURULUŞLARI İLE İLGİLİ GENEL KURALLAR

- 7.1** ISO/IEC 27701 belgelendirme faaliyetleri için UDK'nın ilgili personelinin ISO/IEC 17021-1 ve ISO/IEC 27006 standartlarının "Kaynak Şartları" maddesinde ve ilgili eklerde verilen şartları taşıması gerekmektedir.
- 7.2** ISO/IEC 20000-1 belgelendirme faaliyetleri için UDK'nın ilgili personelinin ISO/IEC 17021-1 ve ISO/IEC 20000-6 standartlarının "Kaynak Şartları" maddesinde ve ilgili eklerde verilen şartları taşıması gerekmektedir.



TÜRK AKREDİTASYON KURUMU

- 7.3** ISO/IEC 27701 belgelendirme faaliyetleri için UDK tetkiklerinde tetkikçi/gün süresini ISO/IEC 27006 standardında verilen süreleri dikkate alarak hesaplamalıdır. ISO/IEC 27701 standardı ISO/IEC 27001 ve ISO/IEC 27002 standartlarına ilave şartlar getirdiği için tetkikçi/gün süreleri hesaplanırken ISO/IEC 27006 standardında verilen sürelerle en az %30 süre ilave edilmelidir.
- 7.4** ISO/IEC 20000-1 belgelendirme faaliyetleri için UDK tetkiklerinde tetkikçi/gün süresini ISO/IEC 20000-6 standardında verilen süreleri dikkate alarak hesaplamalıdır
- 7.5** UDK başka bir UDK tarafından ISO/IEC 27001 belgesine sahip bir işletmeyi tek başına ISO/IEC 27701 tetkiki sonucu belgelendiremez. UDK'nın, ISO/IEC 27701 tetkikini ISO/IEC 27001 tetkiki ile birlikte yapması gerekmektedir.
- 7.6** ISO/IEC 27701 belgelendirmesi yapacak olan UDK, denetim ekibi üyeleri için ISO/IEC 17021-1 ve ISO/IEC 27006 standartlarında verilen yeterlilik kriterlerine ilave olarak asgari aşağıdaki gereklilikleri sağlamalıdır;

Genel yeterlilik gereklilikleri;

- 7.6.1** UDK, denetim ekibi üyelerinin denetleyeceği müşterinin Kişisel Veri Yönetim Sistemi ile ilgili teknolojik, yasal ve düzenleyici gelişmeler hakkında bilgi sahibi olmalarını sağlamalıdır.
- 7.6.2** UDK, ISO/IEC 17021-1 Tablo A.1'de belirtildiği gibi her belgelendirme fonksiyonu için yeterlilik gereksinimlerini tanımlamalıdır. UDK, ISO/IEC 17021-1, ISO/IEC 27006'da belirtilen tüm şartları ve UDK tarafından belirlenen teknik alanlarla ilgili olarak bu rehberi de dikkate almalıdır.

Yeterlilik kriterlerinin belirlenmesi;

- 7.6.3** UDK, denetim ekibi üyelerinin geçmiş deneyimini, eğitimlerini ve diğer bilgilerini doğrulamak için kriterlere sahip olmalı ve bu kriterler en azından aşağıdakileri içermelidir;
- a) Kişisel bilgi yönetimi hakkında bilgi,
 - b) Denetlenecek faaliyetler hakkında teknik bilgi,
 - c) Kişisel Veri Yönetim Sistemi idarecilerinin, kontrolörlerinin, işlemcilerinin ve üçüncü tarafların rolleri ve bunların arasında Kişisel Veri Yönetim Sisteminin etkileşim ve akışları konusunda bilgi,
 - d) Kişisel Veri Yönetim Sistemini anlama ve gerçek bir kişinin tanımlanabilir olarak kabul edilip edilemeyeceğini belirleme yeteneği
 - e) Değerlendirdiği müşterinin Kişisel Veri Yönetim sistemleriyle ilgili gizliliği koruma şartlarını etkileyebilecek farklı faktörler hakkında bilgi.
- 7.6.4** Denetim ekibi, müşterinin yönetim sistemindeki bilgi güvenliği ve mahremiyet olaylarının göstergelerini yönetim sisteminin uygun ilkelerine kadar izleyebilecek yetkinlikte olacaktır.
- 7.6.5** Denetim ekibi, yukarıdaki maddelerle ilgili uygun iş deneyimine ve bunların pratik uygulamasına sahip olacaktır. (Bu, denetçinin bilgi güvenliği ve gizlilik bilgisi yönetiminin tüm alanlarında eksiksiz bir deneyime ihtiyacı olduğu anlamına gelmez, ancak denetim ekibi bir bütün olarak denetlenmekte olan yönetim sisteminin kapsamını kapsaması için yeterli değerlendirme ve deneyime sahip olmalıdır)



TÜRK AKREDİTASYON KURUMU

7.6.6 Denetim ekibinin tüm üyeleri aşağıdaki konularda bilgi sahibi olmalıdır;

- a) Bilgi güvenliği ve mahremiyete özel dokümantasyon yapıları, hiyerarşi ve karşılıklı ilişkiler,
- b) Bilgi güvenliği ve mahremiyet bilgi yönetimi (Kişisel Veri Yönetim Sistemi) ile ilgili araçlar, yöntemler, teknikler ve bunların uygulamalar,
- c) Bilgi güvenliği ve mahremiyet risk değerlendirmesi ve risk yönetimi,
- d) Bilgi güvenliği ve mahremiyet bilgisi yönetimi için geçerli süreçler,
- e) Bilgi güvenliği ve mahrem bilgilerinin korunmasında muhtemelen ilgili veya bir sorun olabilecek mevcut teknoloji,

7.6.7 Bilgi güvenliği ve Kişisel veri yönetimi sistemlerinin denetimine dahil olan denetçiler aşağıdaki konularda bilgi sahibi olmalıdır;

- a) ISO/IEC 27001'de yer alan tüm gereksinimler;
- b) ISO/IEC 27701'de bulunan tüm gereksinimler;
- c) Kişisel veri yönetimi sisteminin en iyi uygulamaları ve gizliliği koruma prosedürleri;
- d) Kişisel veri yönetimi için politikalar ve iş gereksinimleri;
- e) İş sektörüyle ilgili bilgi güvenliği ve gizlilik riskleri

Denetim ekibinin tüm üyeleri aşağıdaki konularda bilgi sahibi olacaktır:

- f) ISO/IEC 27002'de (gerekli olduğu belirlenirse) yer alan tüm kontroller ve bunların uygulanması; ve
- g) ISO/IEC 27701'deki (gerekirse) ek veya değiştirilmiş kontrol hedefleri ve kontrolleri ve bunların uygulanması;
- h) Denetlenmekte olan yönetim sistemi kapsamındaki belirli bilgi güvenliği ve mahremiyet alanı, coğrafya ve hukuki alanlarındaki yasal ve düzenleyici gereklilikler.

7.6.8 Gerekli tetkik ekibi yetkinliğini belirlemek, tetkik ekibi üyelerini seçmek ve tetkik zamanını belirlemekle sorumlu personel aşağıdaki konularda bilgi sahibi olmalıdır:

- a) İlgili bilgi güvenliği ve mahremiyet standartları ve sertifikasyon sürecinde kullanılan diğer normatif belgeler;
- b) Müşteri iş sektörüyle ilgili genel terminoloji, süreçler, teknolojiler ve riskler;
- c) Bilgi güvenliği ve kişisel veri yönetimi sistemlerinin geliştirilmesi ve uygulanmasına ilişkin müşteri ürünleri, süreçleri, organizasyon türleri, boyutu, yönetimi, yapısı, işlevleri ve ilişkileri ve dış kaynak kullanımı işlevleri dahil olmak üzere sertifikasyon faaliyetleri.

7.6.9 Denetim raporlarını gözden geçiren ve belgelendirme kararlarını veren personelin; belgelendirme kapsamını, kapsamdaki değişiklikleri ve bunların denetimin etkinliği üzerindeki etkilerini, özellikle de ilgili riskler ve bağımlılıklar ve bağdaştırıcıların belirlenmesinin devamlı doğrulanması konusunda bilgi sahibi olması garanti altına alınmalıdır. Ayrıca aşağıdaki konularda bilgi sahibi olmalıdırlar;

- a) Bilgi güvenliği ve mahremiyete özel dokümantasyon yapıları, hiyerarşi ve karşılıklı ilişkiler,
- b) Bilgi güvenliği ve mahremiyet risk değerlendirmesi ve risk yönetimi;
- c) Kişisel veri yönetimi için geçerli süreçler;
- d) Bilgi güvenliği ve mahremiyet yönetimi ile ilgili yasal ve düzenleyici gereklilikler;
- e) İlgili bilgi güvenliği ve mahremiyet standartları ve belgelendirme sürecinde kullanılan diğer normatif dokümanlar.



TÜRK AKREDİTASYON KURUMU

Denetçi Bilgi ve Deneyiminin Gösterilmesi

7.6.10 UDK, denetçilerin bilgi ve deneyime sahip olduğunu aşağıdaki yollarla göstermelidir:

- a) Tanınmış bilgi güvenliği ve mahremiyet yönetimine özgü nitelikler (mahremiyet yönetimi ve kişisel olarak tanımlanabilir bilgilerin korunmasının bu yeterliliğin tanımlanmış bir parçası olduğu durumlarda),
- b) Gizlilikle ilgili eğitimlere katılım ve kişisel sertifikalara sahip olma,
- c) Güncel mesleki gelişim kayıtları;
- d) ISO/IEC 27701 ile uzatılan ve denetlenen kapsam için teknik olarak yetkin başka bir denetçi tarafından tanık olunan BGYS denetimleri,
- e) Üniversite eğitimi veya buna eşdeğer profesyonel eğitim,
- f) Bilgi ve iletişim teknolojisinde en az dört yıllık tam zamanlı deneyimine sahip olup, bu deneyimin en az iki yılı bilgi güvenliği ve kişisel olarak tanımlanabilir bilgilerin korunmasına ilişkin bir rol veya işleve sahip olma,
- g) BGYS denetimlerini ve denetim yönetimini kapsayan, en az iki gün özel olarak kişisel veri (mahremiyet) yönetimi ve kişisel olarak tanımlanabilir bilgilerin korunmasına odaklanan en az beş günlük eğitimi başarıyla tamamlanması,
- h) ISO/IEC 27701'in gereksinimlerine göre denetimler gerçekleştirmeden önce bilgi ve güvenlik ve mahremiyet denetimi konusunda deneyim sahibi olmalıdır. Bu deneyim, bilgi güvenliği ve kişisel veri yönetimi konusunda yetkin bir değerlendirici tarafından izlenip sonuçların olumlu olarak bildirilmesi sayesinde kazanılabilir. Deneyim, en az bir bilgi güvenliği ve gizlilik ilk belgelendirme denetimine (Aşama 1 ve Aşama 2) veya yeniden belgelendirme denetimine katılımı içermelidir. Bu deneyim, bilgi güvenliği ve kişisel veri yönetim sistemlerinin en az 10 denetim günü (yerinde) kazanılacak ve son 5 yıl içinde gerçekleştirilecektir. Katılım, dokümantasyon ve risk değerlendirmesinin gözden geçirilmesi, uygulama değerlendirmesi ve denetim raporlamasını içermelidir.
- i) İlgili ve güncel deneyime sahip olma,
- j) Kişisel veri yönetimi ve kişisel olarak tanımlanabilir bilgilerin korunması konusundaki mevcut bilgi ve becerileri sürekli mesleki gelişim yoluyla güncelliğini tutmakla,
- k) ISO/IEC 27701 ile genişletilmiş olduğu üzere, ISO/IEC 27001'e göre bir yönetim sistemini denetleme yeterliliğine sahip olması,

Teknik uzmanlar e, f ve i bendindeki şartlara sahip olmalıdır.